Konzepte

ONTAP 9

NetApp
March 27, 2024

This PDF was generated from https://docs.netapp.com/de-de/ontap/authentication/oauth2-as-servers.html on March 27, 2024. Always check docs.netapp.com for the latest.

Inhalt

Konzepte . . . 1
Autorisierungsserver und Zugriffstoken . . . 1
Optionen für die ONTAP-Clientautorisierung . . . 3
OAuth 2.0-Bereitstellungsszenarien . . . 7
Client-Authentifizierung mit gegenseitigem TLS . . . 10

Konzepte

Autorisierungsserver und Zugriffstoken

Autorisierungsserver führen als zentrale Komponente im OAuth 2.0-Autorisierungs-Framework mehrere wichtige Funktionen aus.

OAuth 2.0-Autorisierungsserver

Autorisierungsserver sind in erster Linie für das Erstellen und Signieren von Zugriffstoken verantwortlich. Diese Token enthalten Identitäts- und Autorisationsinformationen, die es einer Clientanwendung ermöglichen, selektiv auf geschützte Ressourcen zuzugreifen. Die Server sind in der Regel voneinander isoliert und können auf verschiedene Weise implementiert werden, beispielsweise als eigenständiger dedizierter Server oder als Teil eines größeren Identitäts- und Zugriffsverwaltungsprodukts.

> Für einen Autorisierungsserver kann manchmal eine andere Terminologie verwendet werden, insbesondere wenn die OAuth 2.0-Funktionalität in einem größeren Produkt oder einer größeren Lösung zur Identitäts- und Zugriffsverwaltung enthalten ist. Der Begriff **Identity Provider (IdP)** wird beispielsweise häufig mit **Authorization Server** synonym verwendet.

Administration

Zusätzlich zur Ausgabe von Zugriffstoken bieten Autorisierungsserver auch zugehörige Verwaltungsdienste, in der Regel über eine Web-Benutzeroberfläche. Sie können beispielsweise Folgendes definieren und verwalten:

- Benutzer- und Benutzerauthentifizierung
- Bereich
- Administrative Trennung durch Mandanten und Bereiche
- Richtlinienumsetzung
- Anbindung an verschiedene externe Dienste
- Unterstützung für andere Identitätsprotokolle (z. B. SAML)

ONTAP ist mit Autorisierungsservern kompatibel, die dem OAuth 2.0-Standard entsprechen.

Definieren auf ONTAP

Sie müssen einen oder mehrere Autorisierungsserver für ONTAP definieren. ONTAP kommuniziert sicher mit jedem Server, um Token zu überprüfen und andere damit verbundene Aufgaben zur Unterstützung der Client-Anwendungen auszuführen.

Die wichtigsten Aspekte der ONTAP-Konfiguration sind im Folgenden aufgeführt. Siehe auch "OAuth 2.0-Bereitstellungsszenarien" Finden Sie weitere Informationen.

Wie und wo die Zugriffstoken validiert werden

Es gibt zwei Optionen für die Validierung von Zugriffstoken.

- Lokale Validierung

  ONTAP kann Zugriffstoken lokal anhand der Informationen validieren, die vom Autorisierungsserver

bereitgestellt werden, der das Token ausgestellt hat. Die vom Autorisierungsserver abgerufenen Informationen werden von ONTAP zwischengespeichert und in regelmäßigen Abständen aktualisiert.

- Fernintrospektion

  Sie können auch Remote-Introspektion verwenden, um Token auf dem Autorisierungsserver zu validieren. Introspektion ist ein Protokoll, das es autorisierten Parteien ermöglicht, einen Autorisierungsserver nach einem Zugriffstoken abzufragen. Es bietet ONTAP eine Möglichkeit, bestimmte Metadaten aus einem Zugriffstoken zu extrahieren und das Token zu validieren. ONTAP speichert einige Daten aus Gründen der Performance im Cache.

Netzwerkspeicherort

ONTAP befindet sich möglicherweise hinter einer Firewall. In diesem Fall müssen Sie einen Proxy als Teil der Konfiguration identifizieren.

Wie die Autorisierungsserver definiert werden

Sie können einen Autorisierungsserver für ONTAP über eine der Administrationsschnittstellen definieren, einschließlich CLI, System Manager oder REST-API. Beispielsweise verwenden Sie in der CLI den Befehl `security oauth2 client create`.

Anzahl der Autorisierungsserver

Sie können bis zu acht Autorisierungsserver für einen einzelnen ONTAP-Cluster definieren. Der gleiche Autorisierungsserver kann für denselben ONTAP-Cluster mehr als einmal definiert werden, solange die Ansprüche des Emittenten oder des Emittenten/der Zielgruppe eindeutig sind. Zum Beispiel, mit Keycloak wird dies immer der Fall sein, wenn verschiedene Bereiche.

Verwenden von OAuth 2.0-Zugriffstoken

Die von den Autorisierungsservern ausgegebenen OAuth 2.0-Zugriffstoken werden von ONTAP überprüft und für rollenbasierte Zugriffsentscheidungen für die REST-API-Clientanforderungen verwendet.

Abrufen eines Zugriffstoken

Sie müssen ein Zugriffstoken von einem Autorisierungsserver erwerben, der für das ONTAP-Cluster definiert ist, wo Sie die REST-API verwenden. Um ein Token zu erwerben, müssen Sie sich direkt an den Autorisierungsserver wenden.

> ONTAP gibt keine Zugriffstoken aus und leitet Anforderungen von Clients nicht an die Autorisierungsserver weiter.

Wie Sie ein Token anfordern, hängt von mehreren Faktoren ab, darunter:

- Autorisierungsserver und seine Konfigurationsoptionen
- OAuth 2.0 Zuschussart
- Client oder Softwaretool zur Ausgabe der Anforderung

Grant-Typen

Ein *Grant* ist ein gut definierter Prozess, einschließlich einer Reihe von Netzwerkflüssen, die zum anfordern und Empfangen eines OAuth 2.0-Zugriffstoken verwendet werden. Je nach Client-, Umgebungs- und Sicherheitsanforderungen können verschiedene Zuteilungsarten verwendet werden. Eine Liste der gängigen Fördertypen finden Sie in der folgenden Tabelle.

Zuteilungsart	Beschreibung
Client-Anmeldedaten	Ein beliebter Zuschusstyp, der nur auf der Verwendung von Anmeldeinformationen basiert (z. B. eine ID und ein gemeinsam genutzter Schlüssel). Es wird davon ausgegangen, dass der Client eine enge Vertrauensbeziehung zum Ressourcenbesitzer hat.
Passwort	Der Zuteilungstyp für die Kennwortanmeldeinformationen des Ressourceneigentümers kann in Fällen verwendet werden, in denen der Ressourceneigentümer über eine Vertrauensbeziehung zum Client verfügt. Sie kann auch bei der Migration älterer HTTP-Clients zu OAuth 2.0 nützlich sein.
Autorisierungscode	Dies ist eine ideale Zuteilungsart für vertrauliche Clients und basiert auf einem auf Umleitung basierenden Fluss. Es kann verwendet werden, um sowohl ein Zugriffstoken als auch ein Aktualisierungs-Token zu erhalten.

JWT-Inhalt

Ein OAuth 2.0-Zugriffstoken ist als JWT formatiert. Der Inhalt wird basierend auf Ihrer Konfiguration vom Autorisierungsserver erstellt. Die Token sind jedoch für die Client-Anwendungen undurchsichtig. Ein Kunde hat keinen Grund, ein Token zu prüfen oder sich des Inhalts bewusst zu sein.

Jedes JWT-Zugriffstoken enthält eine Reihe von Ansprüchen. Die Ansprüche beschreiben die Merkmale des Emittenten und die Autorisierung basierend auf administrativen Definitionen am Autorisierungsserver. Einige der mit dem Standard registrierten Ansprüche sind in der folgenden Tabelle beschrieben. Bei allen Strings wird zwischen Groß- und Kleinschreibung unterschieden.

Forderung	Stichwort	Beschreibung
Aussteller	ISS	Identifiziert den Prinzipal, der das Token ausgegeben hat. Die Antragsbearbeitung ist anwendungsspezifisch.
Betreff	Unterbereich	Der Betreff oder Benutzer des Tokens. Der Name ist global oder lokal eindeutig.
Zielgruppe	AUD	Die Empfänger, für die das Token bestimmt ist. Als Array von Strings implementiert.
Ablauf	exsp	Die Zeit, nach der das Token abläuft und zurückgewiesen werden muss.

Siehe "RFC 7519: JSON Web Tokens" Finden Sie weitere Informationen.

Optionen für die ONTAP-Clientautorisierung

Für die Anpassung Ihrer ONTAP-Clientautorisierung stehen verschiedene Optionen zur Verfügung. Die Autorisierungsentscheidungen basieren letztlich auf den ONTAP-REST-Rollen, die entweder in den Zugriffstoken enthalten sind oder von diesen abgeleitet wurden.

> Sie können nur verwenden "ONTAP REST-Rollen" Bei der Konfiguration der Autorisierung für OAuth 2.0. Die früheren herkömmlichen ONTAP Rollen werden nicht unterstützt.

Einführung

Die OAuth 2.0 Implementierung in ONTAP ist flexibel und robust und bietet Ihnen die Optionen, die Sie für die Sicherung der ONTAP Umgebung benötigen. Im Wesentlichen gibt es drei Hauptkonfigurationskategorien zur Definition der ONTAP-Clientautorisierung. Diese Konfigurationsoptionen schließen sich gegenseitig aus.

ONTAP wendet je nach Konfiguration die am besten geeignete Option an. Siehe "Wie ONTAP den Zugriff bestimmt" Finden Sie heraus, wie ONTAP Ihre Konfigurationsdefinitionen für Zugriffsentscheidungen verarbeitet.

OAuth 2.0 eigenständige Oszilloskope

Diese Bereiche enthalten eine oder mehrere benutzerdefinierte REST-Rollen, die jeweils in einer einzigen Zeichenfolge gekapselt sind. Sie sind unabhängig von den Rollendefinitionen von ONTAP. Sie müssen diese Bereichszeichenfolgen auf Ihrem Autorisierungsserver definieren.

Lokale ONTAP-spezifische REST-Rollen und Benutzer

Je nach Konfiguration können die lokalen ONTAP-Identitätsdefinitionen für Zugriffsentscheidungen verwendet werden. Folgende Optionen stehen zur Verfügung:

- Einzelne benannte REST-Rolle
- Übereinstimmung des Benutzernamens mit einem lokalen ONTAP-Benutzer

Die scope Syntax für eine benannte Rolle ist **ontap-role-**<URL-encoded-ONTAP-role-name>. Wenn die Rolle beispielsweise „admin“ lautet, lautet der Scope-String „ontap-role-admin“.

Active Directory oder LDAP-Gruppen

Wenn die lokalen ONTAP-Definitionen überprüft werden, aber keine Zugriffsentscheidung getroffen werden kann, werden die Active Directory („Domain“)- oder LDAP („nsswitch“)-Gruppen verwendet. Gruppeninformationen können auf zwei Arten angegeben werden:

- OAuth 2.0-Scope-String

  Unterstützt vertrauliche Anwendungen, die den Ablauf der Clientanmeldeinformationen verwenden, wenn kein Benutzer mit einer Gruppenmitgliedschaft vorhanden ist. Der Umfang sollte benannt werden **ontap-Group-**<URL-encoded-ONTAP-group-name>. Wenn die Gruppe beispielsweise „Entwicklung“ ist, lautet der Scope String „ontap-Group-Development“.

- In der „Gruppe“-Forderung

  Dies ist für Zugriffstoken vorgesehen, die von ADFS unter Verwendung des Ablaufs Resource Owner (Password Grant) ausgegeben werden.

Eigenständige Oszilloskope von OAuth 2.0

In sich geschlossene Bereiche sind Strings, die im Zugriffstoken enthalten sind. Jede dieser Rollen ist vollständig definiert und beinhaltet alles, was ONTAP für eine Zugriffsentscheidung benötigt. Der Umfang unterscheidet sich von jeder der REST-Rollen, die in ONTAP selbst definiert sind.

Format der Bereichszeichenfolge

Auf einer Basisebene wird der Umfang als zusammenhängende Zeichenfolge dargestellt und besteht aus sechs durch Doppelpunkte getrennten Werten. Die im Scope String verwendeten Parameter werden im Folgenden beschrieben.

ONTAP-Literal

Der Bereich muss mit dem Literalwert beginnen `ontap` In Kleinbuchstaben. Der ONTAP-spezifische Umfang wird angegeben.

Cluster

Dies definiert, auf welchen ONTAP Cluster sich der Umfang bezieht. Die Werte können Folgendes umfassen:

- Cluster-UUID

  Identifiziert ein einzelnes Cluster.

- Sternchen (*)

  Gibt an, dass der Umfang auf alle Cluster angewendet wird.

Sie können den ONTAP-CLI-Befehl verwenden `cluster identity show` Um die UUID des Clusters anzuzeigen. Falls nicht angegeben, gilt der Umfang für alle Cluster.

Rolle

Der Name der im eigenständigen Bereich enthaltenen REST-Rolle. Dieser Wert wird von ONTAP nicht untersucht oder auf vorhandene REST-Rollen abgestimmt, die für ONTAP definiert sind. Der Name wird für die Protokollierung verwendet.

Zugangsstufe

Dieser Wert gibt die Zugriffsebene an, die auf die Clientanwendung angewendet wird, wenn der API-Endpunkt im Umfang verwendet wird. Es gibt sechs mögliche Werte, wie in der Tabelle unten beschrieben.

Zugangsstufe	Beschreibung
Keine	Verweigert allen Zugriff auf den angegebenen Endpunkt.
readonly	Nur Lesezugriff mit GET ist möglich.
Read_create	Ermöglicht den Lesezugriff sowie die Erstellung neuer Ressourceninstanzen über POST.
Lesen_ändern	Ermöglicht den Lesezugriff sowie die Möglichkeit, vorhandene Ressourcen mithilfe von PATCHES zu aktualisieren.
Lesen_create_modify	Ermöglicht alle Zugriffe außer Löschen. Zu den zulässigen Operationen gehören GET (read), POST (create) und PATCH (Update).
Alle	Ermöglicht vollständigen Zugriff.

SVM

Der Name der SVM innerhalb des Clusters, für den der Umfang gilt. Verwenden Sie den *-Wert (Sternchen), um alle SVMs anzuzeigen.

> Diese Funktion wird von ONTAP 9.14.1 nicht vollständig unterstützt. Sie können den SVM-Parameter ignorieren und ein Sternchen als Platzhalter verwenden. Überprüfen Sie die "Versionshinweise zu ONTAP" Um auf zukünftige SVM-Unterstützung zu prüfen.

REST-API-URI

Der vollständige oder teilweise Pfad zu einer Ressource oder einem Satz zugehöriger Ressourcen. Der String muss mit beginnen `/api`. Wenn Sie keinen Wert angeben, gilt der Umfang für alle API-Endpunkte im ONTAP-Cluster.

Beispiele für den Umfang

Im Folgenden werden einige Beispiele für eigenständige Oszilloskope vorgestellt.

ontap:*:joes-role:read_create_modify:*:/API/Cluster

Bietet dem Benutzer, dem diese Rolle zugewiesen ist, den Zugriff auf das zu lesen, zu erstellen und zu ändern `/cluster` endpunkt:

CLI-Verwaltungstool

Um die Administration der eigenständigen Bereiche einfacher und weniger fehleranfällig zu machen, bietet ONTAP den CLI-Befehl `security oauth2 scope` So generieren Sie auf der Grundlage Ihrer Eingabeparameter Oszilloskop-Strings.

Der Befehl `security oauth2 scope` Basierend auf Ihren Angaben gibt es zwei Anwendungsfälle:

- CLI-Parameter für den Umfang einer Zeichenfolge

  Mit dieser Version des Befehls können Sie auf Grundlage der Eingabeparameter eine Bereichszeichenfolge generieren.

- Scope-String zu CLI-Parametern

  Sie können diese Version des Befehls verwenden, um die Befehlsparameter basierend auf der Zeichenfolge für den Eingabebereich zu generieren.

Beispiel

Im folgenden Beispiel wird eine Scope-String mit der Ausgabe generiert, die nach dem unten stehenden Befehlsbeispiel enthalten ist. Die Definition gilt für alle Cluster.

```
security oauth2 scope cli-to-scope -role joes-role -access readonly -api
/api/cluster
```

```
ontap:*:joes-role:readonly:*:/api/cluster
```

Wie ONTAP den Zugriff bestimmt

Um OAuth 2.0 richtig zu entwickeln und zu implementieren, müssen Sie verstehen, wie Ihre Autorisierungskonfiguration von ONTAP verwendet wird, um Zugriffsentscheidungen für die Clients zu treffen.

Schritt 1: Eigenständige Bereiche

Wenn das Zugriffstoken eigenständige Bereiche enthält, untersucht ONTAP diese Bereiche zuerst. Wenn keine eigenständigen Bereiche vorhanden sind, mit Schritt 2 fortfahren.

Wenn ein oder mehrere eigenständige Bereiche vorhanden sind, wendet ONTAP jeden Bereich an, bis eine explizite **ALLOW**- oder **DENY**-Entscheidung getroffen werden kann. Wenn eine explizite Entscheidung

getroffen wird, endet die Verarbeitung.

Wenn ONTAP keine explizite Zugriffsentscheidung treffen kann, fahren Sie mit Schritt 2 fort.

Schritt 2: Überprüfen Sie die lokale Rollenmarkierung

ONTAP überprüft den Wert des Flags `use-local-roles-if-present`. Der Wert dieses Flags wird für jeden Autorisierungsserver, der für ONTAP definiert ist, separat festgelegt.

- Wenn der Wert ist `true` Fahren Sie mit Schritt 3 fort.
- Wenn der Wert ist `false` Die Verarbeitung endet und der Zugriff wird verweigert.

Schritt 3: Benannte ONTAP REST-Rolle

Wenn das Zugriffstoken eine benannte REST-Rolle enthält, verwendet ONTAP die Rolle, um die Zugriffsentscheidung zu treffen. Dies führt immer zu einer **ALLOW** oder **DENY** Entscheidung und Verarbeitungsende.

Wenn keine benannte REST-Rolle vorhanden ist oder die Rolle nicht gefunden wurde, fahren Sie mit Schritt 4 fort.

Schritt 4: Lokale ONTAP-Benutzer

Extrahieren Sie den Benutzernamen aus dem Zugriffstoken und versuchen Sie, ihn einem lokalen ONTAP-Benutzer zuzuordnen.

Wenn ein lokaler ONTAP-Benutzer abgeglichen wird, verwendet ONTAP die für den Benutzer definierte Rolle, um eine Zugriffsentscheidung zu treffen. Dies führt immer zu einer **ALLOW** oder **DENY** Entscheidung und Verarbeitungsende.

Wenn ein lokaler ONTAP-Benutzer nicht stimmt oder kein Benutzername im Zugriffstoken vorhanden ist, fahren Sie mit Schritt 5 fort.

Schritt 5: Gruppen-zu-Rollen-Zuordnung

Extrahieren Sie die Gruppe aus dem Zugriffstoken, und versuchen Sie, sie einer Gruppe zuzuordnen. Die Gruppen werden über Active Directory oder einen gleichwertigen LDAP-Server definiert.

Wenn eine Gruppenübereinstimme vorhanden ist, verwendet ONTAP die für die Gruppe definierte Rolle, um eine Zugriffsentscheidung zu treffen. Dies führt immer zu einer **ALLOW** oder **DENY** Entscheidung und Verarbeitungsende.

Wenn keine Gruppenübereinstimme vorhanden ist oder keine Gruppe im Zugriffstoken vorhanden ist, wird der Zugriff verweigert und die Verarbeitung wird beendet.

OAuth 2.0-Bereitstellungsszenarien

Beim Definieren eines Autorisierungsservers für ONTAP stehen verschiedene Konfigurationsoptionen zur Verfügung. Basierend auf diesen Optionen können Sie einen Autorisierungsserver erstellen, der für Ihre Bereitstellungsumgebung geeignet ist.

Zusammenfassung der Konfigurationsparameter

Beim Definieren eines Autorisierungsservers für ONTAP stehen mehrere Konfigurationsparameter zur Verfügung. Diese Parameter werden in der Regel in allen administrativen Schnittstellen unterstützt.

Die Parameternamen können je nach ONTAP-Administratorschnittstelle leicht variieren. Bei der Konfiguration der Remote-Introspektion wird der Endpunkt beispielsweise mit dem CLI-Befehlsparameter identifiziert `-introspection-endpoint`. Aber mit dem System Manager ist das äquivalente Feld *Authorization Server Token Introspection URI*. Um alle ONTAP-Verwaltungsschnittstellen aufzunehmen, wird eine allgemeine Beschreibung der Parameter bereitgestellt. Der genaue Parameter oder das Feld sollte je nach Kontext offensichtlich sein.

Parameter	Beschreibung
Name	Der Name des Autorisierungsservers, der ONTAP bekannt ist.
Applikation	Die ONTAP-interne Anwendung, für die die Definition gilt. Dies muss **http** sein.
Aussteller-URI	Der FQDN mit Pfad, der den Standort oder die Organisation identifiziert, der die Token ausgibt.
Provider-JWKS-URI	Der FQDN mit Pfad und Dateiname, bei dem ONTAP die JSON-Webschlüsselsätze erhält, die zur Validierung der Zugriffstoken verwendet werden.
JWKS-Aktualisierungsintervall	Das Zeitintervall, in dem festgelegt wird, wie oft ONTAP Zertifikatsinformationen vom Provider JWKS URI aktualisiert. Der Wert wird im ISO-8601-Format angegeben.
Introspektion Endpunkt	Der FQDN mit Pfad, den ONTAP zur Remote-Token-Validierung durch Introspektion verwendet.
Client-ID	Der Name des Clients, wie er auf dem Autorisierungsserver definiert ist. Wenn dieser Wert enthalten ist, müssen Sie auch den zugehörigen Client-Schlüssel basierend auf der Schnittstelle angeben.
Ausgehender Proxy	Damit wird der Zugriff auf den Autorisierungsserver ermöglicht, wenn sich ONTAP hinter einer Firewall befindet. Der URI muss im Curl-Format vorliegen.
Verwenden Sie ggf. lokale Rollen	Ein boolesches Flag, das bestimmt, ob die lokalen ONTAP-Definitionen verwendet werden, einschließlich einer benannten REST-Rolle und lokalen Benutzern.
Benutzeranspruch entfernen	Ein alternativer Name, den ONTAP für lokale Benutzer verwendet. Verwenden Sie die `sub` Feld im Zugriffstoken, das mit dem lokalen Benutzernamen übereinstimmt.

Bereitstellungsszenarien

Im Folgenden werden verschiedene gängige Bereitstellungsszenarien vorgestellt. Sie sind abhängig davon organisiert, ob die Token-Validierung lokal durch ONTAP oder Remote durch den Autorisierungsserver durchgeführt wird. Jedes Szenario enthält eine Liste der erforderlichen Konfigurationsoptionen. Siehe "Implementieren Sie OAuth 2.0 in ONTAP" Beispiele für Konfigurationsbefehle.

> Nachdem Sie einen Autorisierungsserver definiert haben, können Sie seine Konfiguration über die ONTAP-Verwaltungsschnittstelle anzeigen. Verwenden Sie beispielsweise den Befehl `security oauth2 client show` Mit der ONTAP CLI.

Lokale Validierung

Die folgenden Bereitstellungsszenarien basieren auf der lokalen Tokenvalidierung durch ONTAP.

Verwenden Sie eigenständige Bereiche ohne Proxy

Dies ist die einfachste Bereitstellung, bei der nur OAuth 2.0 eigenständige Bereiche verwendet werden. Keine der lokalen ONTAP-Identitätsdefinitionen werden verwendet. Sie müssen die folgenden Parameter angeben:

- Name
- Anwendung (http)
- Provider-JWKS-URI
- Aussteller-URI

Sie müssen die Gültigkeitsbereiche auch auf dem Autorisierungsserver hinzufügen.

Verwenden Sie eigenständige Bereiche mit einem Proxy

In diesem Bereitstellungsszenario werden die eigenständigen Oszilloskope von OAuth 2.0 verwendet. Keine der lokalen ONTAP-Identitätsdefinitionen werden verwendet. Aber der Autorisierungsserver befindet sich hinter einer Firewall und Sie müssen daher einen Proxy konfigurieren. Sie müssen die folgenden Parameter angeben:

- Name
- Anwendung (http)
- Provider-JWKS-URI
- Ausgehender Proxy
- Aussteller-URI
- Zielgruppe

Sie müssen die Gültigkeitsbereiche auch auf dem Autorisierungsserver hinzufügen.

Verwenden Sie lokale Benutzerrollen und die standardmäßige Zuweisung von Benutzernamen mit einem Proxy

Dieses Bereitstellungsszenario verwendet lokale Benutzerrollen mit Standardnamenszuordnung. Der Anspruch des Remotebenutzers verwendet den Standardwert `sub` Daher wird dieses Feld im Zugriffstoken verwendet, um mit dem lokalen Benutzernamen zu übereinstimmen. Der Benutzername darf maximal 40 Zeichen lang sein. Der Autorisierungsserver befindet sich hinter einer Firewall, Sie müssen also auch einen Proxy konfigurieren. Sie müssen die folgenden Parameter angeben:

- Name
- Anwendung (http)
- Provider-JWKS-URI
- Verwenden Sie ggf. lokale Rollen (`true`)
- Ausgehender Proxy
- Aussteller

Sie müssen sicherstellen, dass der lokale Benutzer für ONTAP definiert ist.

Verwenden Sie lokale Benutzerrollen und alternative Benutzernamen-Zuordnungen mit einem Proxy

Dieses Bereitstellungsszenario verwendet lokale Benutzerrollen mit einem alternativen Benutzernamen, der für einen lokalen ONTAP-Benutzer verwendet wird. Der Autorisierungsserver befindet sich hinter einer Firewall, Sie müssen also einen Proxy konfigurieren. Sie müssen die folgenden Parameter angeben:

- Name
- Anwendung (http)
- Provider-JWKS-URI
- Verwenden Sie ggf. lokale Rollen (`true`)
- Anspruch des Remote-Benutzers
- Ausgehender Proxy
- Aussteller-URI
- Zielgruppe

Sie müssen sicherstellen, dass der lokale Benutzer für ONTAP definiert ist.

Fernintrospektion

Die folgenden Bereitstellungskonfigurationen basieren auf ONTAP, die Token per Remote-Prüfung durch Introspektion validieren.

Verwenden Sie eigenständige Bereiche ohne Proxy

Dies ist eine einfache Bereitstellung, die auf der Verwendung der eigenständigen Oszilloskope von OAuth 2.0 basiert. Keine der ONTAP-Identitätsdefinitionen wird verwendet. Sie müssen die folgenden Parameter einschließen:

- Name
- Anwendung (http)
- Introspektion Endpunkt
- Client-ID
- Aussteller-URI

Sie müssen die Bereiche sowie den Client- und Client-Schlüssel auf dem Autorisierungsserver definieren.

Client-Authentifizierung mit gegenseitigem TLS

Je nach Ihren Sicherheitsanforderungen können Sie optional Mutual TLS (MTLS) zur Implementierung einer starken Clientauthentifizierung konfigurieren. Bei Verwendung mit ONTAP als Teil einer OAuth 2.0-Bereitstellung garantiert MTLS, dass die Zugriffstoken nur von den Clients verwendet werden, für die sie ursprünglich ausgegeben wurden.

Gegenseitiges TLS mit OAuth 2.0

Transport Layer Security (TLS) wird verwendet, um einen sicheren Kommunikationskanal zwischen zwei Anwendungen herzustellen, in der Regel zwischen einem Client-Browser und einem Webserver. Mutual TLS erweitert dies durch eine starke Identifizierung des Clients über ein Client-Zertifikat. Bei Verwendung in einem ONTAP-Cluster mit OAuth 2.0 wird die Basis-MTLS-Funktionalität durch das Erstellen und Verwenden von Sender-beschränkten Zugriffstoken erweitert.

Ein vom Absender beschränktem Zugriffstoken kann nur vom Client verwendet werden, an den es ursprünglich ausgegeben wurde. Um diese Funktion zu unterstützen, muss ein neuer Bestätigungsantrag gestellt werden (`cnf`) Wird in das Token eingefügt. Das Feld enthält die Eigenschaft `x5t#S256` Enthält einen Digest des

Clientzertifikats, das bei der Anforderung des Zugriffstoken verwendet wird. Dieser Wert wird von ONTAP im Rahmen der Überprüfung des Tokens überprüft. Von Autorisierungsservern ausgegebene Zugriffstoken, die nicht durch den Absender eingeschränkt sind, enthalten keinen zusätzlichen Bestätigungsanspruch.

Sie müssen ONTAP so konfigurieren, dass MTLS für jeden Autorisierungsserver separat verwendet wird. Beispiel: Der CLI-Befehl `security oauth2 client` Enthält den Parameter `use-mutual-tls` Zur Steuerung der MTLS-Verarbeitung anhand von drei Werten, wie in der folgenden Tabelle dargestellt.

> In jeder Konfiguration hängen das Ergebnis und die von ONTAP ergriffenen Maßnahmen vom Wert des Konfigurationsparameters sowie vom Inhalt des Zugriffstoken und des Clientzertifikats ab. Die Parameter in der Tabelle sind vom kleinsten bis zum restriktivsten organisiert.

Parameter	Beschreibung
Keine	Die gegenseitige TLS-Authentifizierung OAuth 2.0 ist für den Autorisierungsserver vollständig deaktiviert. ONTAP führt keine MTLS-Clientzertifikatauthentifizierung durch, selbst wenn der Bestätigungsanspruch im Token vorhanden ist oder ein Clientzertifikat mit der TLS-Verbindung geliefert wird.
Anforderung	Die gegenseitige TLS-Authentifizierung von OAuth 2.0 wird erzwungen, wenn ein vom Absender beschränktes Zugriffstoken vom Client angezeigt wird. Das heißt, MTLS wird nur erzwungen, wenn die Bestätigung Anspruch (mit Eigentum `x5t#S256`) Ist im Access-Token vorhanden. Dies ist die Standardeinstellung.
Erforderlich	Die gegenseitige TLS-Authentifizierung OAuth 2.0 wird für alle Zugriffstoken durchgesetzt, die vom Autorisierungsserver ausgegeben werden. Daher müssen alle Zugriffstoken durch den Absender eingeschränkt sein. Die Authentifizierung und die REST-API-Anforderung schlagen fehl, wenn der Bestätigungsanspruch nicht im Zugriffstoken vorhanden ist oder wenn ein ungültiges Clientzertifikat vorliegt.

Grundlegende Implementierungsablaufs

Die typischen Schritte bei der Verwendung von MTLS mit OAuth 2.0 in einer ONTAP-Umgebung sind nachfolgend dargestellt. Siehe "RFC 8705: OAuth 2.0 Mutual-TLS Client Authentication und Certificate-bound Access Tokens" Entnehmen.

Schritt 1: Erstellen und installieren Sie ein Client-Zertifikat

Die Ermittlung der Kundenidentität basiert auf dem Nachweis der Kenntnis eines privaten Kundenschlüssels. Der entsprechende öffentliche Schlüssel wird in ein signiertes X.509-Zertifikat gelegt, das vom Client vorgelegt wird. Auf einer übergeordneten Ebene umfassen die Schritte zur Erstellung des Clientzertifikats Folgendes:

1. Erzeugen Sie ein öffentliches und privates Schlüsselpaar
2. Erstellen Sie eine Zertifikatsignierungsanforderung
3. Senden Sie die CSR-Datei an eine bekannte Zertifizierungsstelle
4. CA überprüft die Anforderung und stellt das signierte Zertifikat aus

Sie können das Clientzertifikat normalerweise in Ihrem lokalen Betriebssystem installieren oder direkt mit einem gängigen Dienstprogramm wie Curl verwenden.

Schritt 2: Konfigurieren Sie ONTAP für die Verwendung von MTLS

Sie müssen ONTAP für die Verwendung von MTLS konfigurieren. Diese Konfiguration erfolgt für jeden Autorisierungsserver separat. Beispielsweise mit dem CLI-Befehl `security oauth2 client` Wird mit dem

optionalen Parameter verwendet `use-mutual-tls`. Siehe "Implementieren Sie OAuth 2.0 in ONTAP" Finden Sie weitere Informationen.

Schritt 3: Client fordert ein Zugriffstoken an

Der Client muss ein Zugriffstoken vom Autorisierungsserver anfordern, der für ONTAP konfiguriert ist. Die Client-Anwendung muss MTLS mit dem in Schritt 1 erstellten und installierten Zertifikat verwenden.

Schritt 4: Der Autorisierungsserver generiert das Zugriffstoken

Der Autorisierungsserver überprüft die Clientanforderung und erstellt ein Zugriffstoken. Dazu wird ein Nachrichtendigest des Client-Zertifikats erstellt, das als Bestätigungsforderung im Token enthalten ist (Feld `cnf`).

Schritt 5: Client-Anwendung präsentiert das Zugriffstoken an ONTAP

Die Client-Anwendung führt einen REST-API-Aufruf zum ONTAP-Cluster durch und schließt das Zugriffstoken in den Header der Autorisierungsanforderung als **Bearer Token** ein. Der Client muss MTLS mit demselben Zertifikat verwenden, das für die Anforderung des Zugriffstoken verwendet wird.

Schritt 6: ONTAP überprüft Client und Token.

ONTAP erhält das Zugriffstoken in einer HTTP-Anfrage sowie das Clientzertifikat, das als Teil der MTLS-Verarbeitung verwendet wird. ONTAP validiert zuerst die Signatur im Zugriffstoken. Basierend auf der Konfiguration generiert ONTAP einen Nachrichtendigest des Client-Zertifikats und vergleicht ihn mit dem Bestätigungsanspruch **cnf** im Token. Wenn die beiden Werte übereinstimmen, hat ONTAP bestätigt, dass der Client, der die API-Anforderung erstellt, derselbe Client ist, für den das Zugriffstoken ursprünglich ausgegeben wurde.

Copyright-Informationen

Copyright © 2024 NetApp. Alle Rechte vorbehalten. Gedruckt in den USA. Dieses urheberrechtlich geschützte Dokument darf ohne die vorherige schriftliche Genehmigung des Urheberrechtsinhabers in keiner Form und durch keine Mittel – weder grafische noch elektronische oder mechanische, einschließlich Fotokopieren, Aufnehmen oder Speichern in einem elektronischen Abrufsystem – auch nicht in Teilen, vervielfältigt werden.

Software, die von urheberrechtlich geschütztem NetApp Material abgeleitet wird, unterliegt der folgenden Lizenz und dem folgenden Haftungsausschluss:

DIE VORLIEGENDE SOFTWARE WIRD IN DER VORLIEGENDEN FORM VON NETAPP ZUR VERFÜGUNG GESTELLT, D. H. OHNE JEGLICHE EXPLIZITE ODER IMPLIZITE GEWÄHRLEISTUNG, EINSCHLIESSLICH, JEDOCH NICHT BESCHRÄNKT AUF DIE STILLSCHWEIGENDE GEWÄHRLEISTUNG DER MARKTGÄNGIGKEIT UND EIGNUNG FÜR EINEN BESTIMMTEN ZWECK, DIE HIERMIT AUSGESCHLOSSEN WERDEN. NETAPP ÜBERNIMMT KEINERLEI HAFTUNG FÜR DIREKTE, INDIREKTE, ZUFÄLLIGE, BESONDERE, BEISPIELHAFTE SCHÄDEN ODER FOLGESCHÄDEN (EINSCHLIESSLICH, JEDOCH NICHT BESCHRÄNKT AUF DIE BESCHAFFUNG VON ERSATZWAREN ODER -DIENSTLEISTUNGEN, NUTZUNGS-, DATEN- ODER GEWINNVERLUSTE ODER UNTERBRECHUNG DES GESCHÄFTSBETRIEBS), UNABHÄNGIG DAVON, WIE SIE VERURSACHT WURDEN UND AUF WELCHER HAFTUNGSTHEORIE SIE BERUHEN, OB AUS VERTRAGLICH FESTGELEGTER HAFTUNG, VERSCHULDENSUNABHÄNGIGER HAFTUNG ODER DELIKTSHAFTUNG (EINSCHLIESSLICH FAHRLÄSSIGKEIT ODER AUF ANDEREM WEGE), DIE IN IRGENDEINER WEISE AUS DER NUTZUNG DIESER SOFTWARE RESULTIEREN, SELBST WENN AUF DIE MÖGLICHKEIT DERARTIGER SCHÄDEN HINGEWIESEN WURDE.

NetApp behält sich das Recht vor, die hierin beschriebenen Produkte jederzeit und ohne Vorankündigung zu ändern. NetApp übernimmt keine Verantwortung oder Haftung, die sich aus der Verwendung der hier beschriebenen Produkte ergibt, es sei denn, NetApp hat dem ausdrücklich in schriftlicher Form zugestimmt. Die Verwendung oder der Erwerb dieses Produkts stellt keine Lizenzierung im Rahmen eines Patentrechts, Markenrechts oder eines anderen Rechts an geistigem Eigentum von NetApp dar.

Das in diesem Dokument beschriebene Produkt kann durch ein oder mehrere US-amerikanische Patente, ausländische Patente oder anhängige Patentanmeldungen geschützt sein.

ERLÄUTERUNG ZU „RESTRICTED RIGHTS“: Nutzung, Vervielfältigung oder Offenlegung durch die US-Regierung unterliegt den Einschränkungen gemäß Unterabschnitt (b)(3) der Klausel „Rights in Technical Data – Noncommercial Items“ in DFARS 252.227-7013 (Februar 2014) und FAR 52.227-19 (Dezember 2007).

Die hierin enthaltenen Daten beziehen sich auf ein kommerzielles Produkt und/oder einen kommerziellen Service (wie in FAR 2.101 definiert) und sind Eigentum von NetApp, Inc. Alle technischen Daten und die Computersoftware von NetApp, die unter diesem Vertrag bereitgestellt werden, sind gewerblicher Natur und wurden ausschließlich unter Verwendung privater Mittel entwickelt. Die US-Regierung besitzt eine nicht ausschließliche, nicht übertragbare, nicht unterlizenzierbare, weltweite, limitierte unwiderrufliche Lizenz zur Nutzung der Daten nur in Verbindung mit und zur Unterstützung des Vertrags der US-Regierung, unter dem die Daten bereitgestellt wurden. Sofern in den vorliegenden Bedingungen nicht anders angegeben, dürfen die Daten ohne vorherige schriftliche Genehmigung von NetApp, Inc. nicht verwendet, offengelegt, vervielfältigt, geändert, aufgeführt oder angezeigt werden. Die Lizenzrechte der US-Regierung für das US-Verteidigungsministerium sind auf die in DFARS-Klausel 252.227-7015(b) (Februar 2014) genannten Rechte beschränkt.

Markeninformationen

NETAPP, das NETAPP Logo und die unter http://www.netapp.com/TM aufgeführten Marken sind Marken von NetApp, Inc. Andere Firmen und Produktnamen können Marken der jeweiligen Eigentümer sein.